

See discussions, stats, and author profiles for this publication at: <https://www.researchgate.net/publication/382183250>

Cyber Security & Ethical Hacking

Book · June 2024

CITATIONS

2

READS

10,843

1 author:



[Mohammad Shakhawat Khan](#)

Bangladesh University of Engineering and Technology

3 PUBLICATIONS 2 CITATIONS

SEE PROFILE

Cyber Security & Ethical Hacking

By

Mohammad Shakhawat Khan

User ID - shakhawatkhan79

A thesis submitted in partial fulfillment of the requirements for the course of

Cyber Security & Ethical Hacking



Arena Web Security, Dhaka, Bangladesh
June, 2024

Declaration

I, Mohammad Shakhawat Khan currently a final year Bachelor student of Naval Architecture and Marine Engineering in Bangladesh University of Engineering and Technology, do hereby declare that the study presented in this paper titled **“Cyber Security and Ethical Hacking”** is my original work.

I have appropriately acknowledged and referred to all external sources of information and ideas in the text, and included them in the bibliography. I verify that this paper is not submitted to other university, institute and any diploma or internship program for any award, degree or qualification.

I have obtained the necessary permissions and approvals for the use of copyrighted materials, data, or other resources referenced in this thesis. I take full responsibility for the accuracy, integrity, and ethical conduct of this thesis and affirm my commitment to upholding academic honesty and integrity standards.

Signature of the Candidate

Mohammad Shakhawat Khan
User ID: shakhawatkhan79
Date:

Certificate of Thesis

This is to make sure that Mohammad Shakhawat Khan completed effectively the thesis titled "Cyber Security and Ethical Hacking" under my supervision as a supervisee at Arena Web Security. The thesis was conducted in partial fulfillment of the requirements for the course of Cyber Security & Ethical Hacking. The thesis was produced and the study was conducted with praiseworthy dedication, diligence, and academic discipline by **Mohammad Shakhawat Khan** during the course of this thesis. His thesis endeavors exemplified a high standard of academic excellence and provided valuable insights to the discipline of cyber security.

A comprehensive understanding of the subject matter is demonstrated by the thesis, This thesis represents an original contribution to knowledge. The thesis presents a comprehensive and scholarly approach to addressing the thesis objectives through the thesis methodologies, analyses, and conclusions.

I hereby confirm that Mohammad Shakhawat Khan has satisfactorily defended the thesis before the examination committee and has fulfilled the requirements for the completion of cyber security & ethical hacking at arena web security.

Supervisor

Tanjim Al Fahim

Chief Executive Officer (CEO)

Arena Web Security

Dhaka, Bangladesh

Dedicated To-
My Beloved Parents
&
Respected Teachers

Acknowledgement

I would like to express my profound gratitude to my thesis supervisor **Tanjim Al Fahim**, Chief Executive Officer of Arena Web Security, for giving me the opportunity to work on it. Without his continuous support, ideas, guidelines and encouragements this challenging work would not have been possible to be completed successfully.

I want to thank **Md Ashif Islam**, Faculty of Arena Web Security for teaching me the topics related to the course very elaborately.

I am also thankful to **Romaan Moonshi, Bijoy Chandra Mondal, Syed Sakib Alam Mubin** to support the whole journey of this course with their excellent technical support and advices.

I would like to thank all others who are directly or indirectly related to this thesis by sharing their ideas, suggestions and thus supporting us. Finally, I am grateful to my parents and other family members for their constant encouragement and support.

Mohammad Shakhawat Khan

User ID-shakhawatkhan79

Abstract

This thesis focuses on the fields of cybersecurity and ethical hacking, examining different methods, tools, and platforms used to protect digital assets and detect weaknesses. The study starts by providing an overview of ethical hacking and the fundamentals of SQL injection. It then covers various topics including OSINT techniques for monitoring specific individuals, DOS and DDOS attacks, session hijacking, both automatic and manual SQL injection methods, and methods for bypassing Web Application Firewalls (WAF) using error-based and post-based techniques. In addition, it explores the deployment of webshells, the uploading of shells, and the consequences of Bad USB and keyloggers. In addition, the thesis investigates LFI (Local File Inclusion), RFI (Remote File Inclusion), and RCE (Remote Code Execution) vulnerabilities, as well as CSRF (Cross-Site Request Forgery), XSS (Cross-Site Scripting), and social engineering assaults. Additionally, it offers valuable knowledge on effectively employing tools such as Burp Suite for doing web application security testing and resolving challenges presented in PortSwigger laboratories. Additionally, it examines the application of Kali Linux for ethical hacking and utilizes Nmap for doing port scanning, including FIN, XMAS, TCP, and UDP scans. Finally, it examines the methodology, tools, and vulnerabilities involved in website penetration testing. It also investigates the practice of outsourcing security testing through sites such as Fiverr, HackerOne, and Bugcrowd. This thesis intends to get a thorough comprehension of cybersecurity and ethical hacking techniques, tools, and platforms by conducting a detailed analysis of these subjects. The ultimate goal is to enable the creation of efficient strategies for safeguarding digital assets and reducing the impact of cyber attacks.

Table of Contents

DECLARATION.....	I
CERTIFICATE OF THESIS.....	II
ACKNOWLEDGEMENT.....	IV
ABSTRACT.....	V
TABLE OF CONTENTS	VI
TABLE OF FIGURES.....	IX
NOMENCLATURE	XII
ACRONYMS.....	XII
CHAPTER 1: ETHICAL HACKING & BASIC SQL INJECTION	1
1.1 EXPLORING ETHICAL HACKING: OPPORTUNITIES, IMPORTANCE, AND CAREER PATHS	1
1.2 BASIC SQL INJECTION	1
CHAPTER 2: OSINT	4
2.1 OSINT AND LIVE PROJECT	4
2.2 TRACKING OF A TARGET PERSON	5
CHAPTER 3: DOS, DDOS, LIVE DDOS & SESSION HIJACKING	6
3.1 DOS & DDOS	6
3.2 LIVE DDOS ATTACK	6
3.3 SESSION HIJACKING	7
CHAPTER 4: AUTOMATIC AND MANUAL SQL INJECTION.....	9
4.1 AUTOMATIC SQLI BY HAVIJ.....	9
4.2 MANUAL SQLI	11
CHAPTER 5: WAF BYPASS SQL INJECTION (ERROR BASED & X-PATH BASED)	13
5.1 WAF BYPASS SQL INJECTION.....	13
5.2 ERROR BASED SQL INJECTION	15
5.3 X-PATH BASED SQL INJECTION.....	16
CHAPTER 6: WEBSHELL	17
6.1 WEBSHELL	17
6.2 SHELL UPLOAD	17
CHAPTER 7: BAD USB & SKEYLOGGER.....	18
7.1 KEYLOGGER.....	18
7.2 RASPBERRY PI PICO	18
7.3 WIFI DUCKY	18
7.4 FLIPPERZERO	18
7.4 SKEYLOGGER	19
CHAPTER 8: LFI/RFI/RCE	20
8.1 LFI	20
8.2 RFI.....	21
CHAPTER 9: CSRF & XSS	22

9.1 CROSS SITE REQUEST FORGERY (CSRF)	22
9.2 CROSS SITE SCRIPTING (XSS)	24
CHAPTER 10: BURP SUITE	26
10.1 BURP SUITE	26
CHAPTER 11: PORTSWIGGER LAB SOLVE	28
11.1 PORTSWIGGER CSRF LAB SOLVE	28
CHAPTER 12: KALI LINUX	29
12.1 KALI LINUX	29
CHAPTER 13: NMAP, FIN SCAN, TCP SCAN, UDP SCAN	33
13.1 NMAP	33
13.2 FIN SCAN	35
13.3 XMAS SCAN	36
13.4 TCP SCAN	38
13.5 UDP SCAN	39
CHAPTER 14: WEBSITE PENETRATION TESTING & VULNERABILITIES	40
14.1 WEBSITE PENETRATION TESTING	40
14.2 WEBSITE PENETRATION TESTING TOOL	41
14.3 VULNERABILITIES	42
CHAPTER 15: FIVERR	44
15.1 FIVERR	44
CHAPTER 16: HACKERONE & BUGCROUD	45
16.1 OUTSOURCING IN HACKERONE & BUGCROUD	45
APPENDIX A:	46
A.1.1 BASIC SQL INJECTION	46
A.2.1 TRACKING OF A TARGET PERSON	47
A.3.1 LIVE DDOS ATTACK	49
A.3.2 SESSION HIJACKING	51
A.4.1 AUTOMATIC SQLI BY HAVIJ	53
A.4.2 MANUAL SQL INJECTION	55
A.5.1 WAF BYPASS SQL INJECTION	59
A.5.2 ERROR BASED SQL INJECTION	63
A.5.3 X-PATH BASED SQL INJECTION	67
A.6.1 SHELL UPLOAD	71
A.7.1 SKEYLOGGER IN KALI LINUX	74
A.8.1 LFI	76
A.9.1 CROSS SITE REQUEST FORGERY	78
A.9.2 CROSS SITE SCRIPTING	82
A.10.1 BURP SUITE	83
A.11.1 PORTSWIGGER LAB SOLVE	87
A.12.1 KALI LINUX	91
A.13.1 NMAP SCAN	93
A.13.2 FIN SCAN	98
A.13.3 XMAS SCAN	98
A.13.4 TCP SCAN	99
A.13.5 UDP SCAN	99

A.14.1 ACUNETIX.....100

Table of Figures

FIGURE 1.2.1 : LOGIN INTERFACE OF BASIC SQL VULNERABLE SITE.	3
FIGURE 1.2.2 : ADMIN PANEL ACCESS TAKEN BY BASIC SQL INJECTION.	3
FIGURE 2.1.1 : THE FAMILY PICTURE OF NAZIBUL ISLAM EXTRACTED USING OSINT.	4
FIGURE 2.2.1 : TRACKING DETAILS OF A TARGET PERSON WITH GPS LOCATION.	5
FIGURE 3.2.1 : LIVE DDOS ATTACK.	6
FIGURE 3.3.1 : ADMIN PAGE FINDING USING LINK.	8
FIGURE 3.3.2 : ADMIN PANEL ACCESS BY NO REDIRECT.	8
FIGURE 4.1.1 : ADMIN USERNAME AND PASSWD EXTRACTED USING HAVIJ.	10
FIGURE 4.2.2 : ADMIN ID AND PASSWORD IS EXTRACTED BY MANUAL INJECTION.	11
FIGURE 5.1.1 : WEB APPLICATION FIREWALL.	13
FIGURE 5.1.2 : USER ID AND PASSWORD EXTRACTED OF TARGET WEBSITE BY WAF BYPASS SQL INJECTION.	14
FIGURE 5.2.1 : DATA DUMP USING ERROR BASED SQL INJECTION.	15
FIGURE 5.3.1 : DATA DUMP USING X-PATH BASED SQL INJECTION.	16
FIGURE 6.2.1 : SHELL UPLOAD SUCCESSFUL.	17
FIGURE 7.4.1: SKEYLOGGER RECORD OF ALL THE KEY PRESSED AFTER INSTALLATION.	19
FIGURE 8.1.1 : LFI PAYLOAD TO A TARGET SITE.	20
FIGURE 9.1.1 : CROSS SITE REQUEST FORGERY ATTACK.	22
FIGURE 9.1.2 : SCRIPT IS CONVERTED TO URL AND DELIVERED FOR CSRF ATTACK EXECUTED SUCCESSFULLY.	23
FIGURE 9.2.1 : XSS ATTACK SUCCESSFUL EXECUTION ON TARGET SITE.	25
FIGURE 10.1.1 : INTERMEDIATE REQUEST TO GET IN TO A SERVER.	26
FIGURE 10.1.2: DIFFERENT USER ID AND PASSWORD PAYLOAD TEST USING BURP SUITE INTRUDER ATTACK.	27
FIGURE 11.1.1 : PORTSWIGGER CSRF LIVE LAB SOLVE.	28
FIGURE 12.1.3 : ADMIN PANEL EXTRACTION USING FFUF IN KALI LINUX.	32
FIGURE 13.1.1 : NMAP SCAN.	34
FIGURE 13.1.2 : NMAP EXPLOIT DETECTION.	34
FIGURE 13.2.1 : NMAP FIN SCAN.	35
FIGURE 13.3.1 : NMAP XMAS SCAN.	37
FIGURE 13.4.1 : TCP SCAN.	38
FIGURE 13.5.1 : UDP SCAN.	39
FIGURE 14.3.1 : DIFFERENT TYPES OF VULNERABILITIES USING ACUNETIX.	43
FIGURE A.1.1.1 : TAKEN ACCESS OF A SITE BY BASIC SQL INJECTION.	46
FIGURE A.2.1.1 : CUSTOM URL CREATION BY GRABIFY.	47
FIGURE A.2.1.2 : CUSTOM URL CREATED BY GRABIFY.	47
FIGURE A.2.1.3 : TRACKING DETAILS OF A TARGET PERSON USING IP ADDRESS TRACKER.	48
FIGURE A.3.1.1 : HOIC SOFTWARE INTERFACE AND TARGET URL SETUP.	49
FIGURE A.3.1.2 : SETTING UP THE NUMBER OF THREADS FOR DDOS ATTACK.	49
FIGURE A.3.1.3 : DDOS ATTACK USING HOIC.	50
FIGURE A.3.2.1 : REDIRECT TO LOGIN PAGE INTERFACE.	51
FIGURE A.3.2.2 : BLOCKING OF REDIRECT URL.	51
FIGURE A.3.2.3 : ADMIN PANEL ACCESS BY NO REDIRECT.	52
FIGURE A.4.1.1 : TARGET URL ADDED TO HAVIJ.	53
FIGURE A.4.1.2 : THE EXTRACTION OF USERNAME AND PASSWORD FOR THE TARGET WEBSITE.	54
FIGURE A.4.2.1 : SITE INTERFACE IN CYBERFOX BROWSER.	55
FIGURE A.4.2.2 : SITE INTERFACE AFTER POINT INJECTION IN CYBERFOX BROWSER.	55
FIGURE A.4.2.3 : FINDING THE TOTAL NUMBER OF TABLE. (HERE TABLE NUMBER IS 30)	56
FIGURE A.4.2.4 : VULNERABLE TABLE EXTRACTION.	57
FIGURE A.4.2.5 : VULNERABLE TABLE VERSION.	57
FIGURE A.4.2.6 : WEBSITE TABLE EXTRACTION BY DIOS.	58
FIGURE A.4.2.7 : USER ID AND PASSWORD EXTRACTED OF TARGET WEBSITE BY MANUAL SQL INJECTION.	58
FIGURE A.5.1.1 : SITE INTERFACE IN CYBERFOX BROWSER.	59
FIGURE A.5.1.2 : SITE INTERFACE AFTER POINT INJECTION IN CYBERFOX BROWSER.	59

FIGURE A.5.1.3 : FINDING THE TOTAL NUMBER OF TABLE. (HERE TABLE NUMBER IS 6)	60
FIGURE A.5.1.4 : VULNERABLE TABLE EXTRACTION BY WAF BYPASS.. (HERE VULNERABLE TABLE IS 2	60
FIGURE A.5.1.5 : WEBSITE TABLE EXTRACTION BY WAF DIOS.....	61
FIGURE A.5.1.6 : USER ID AND PASSWORD EXTRACTED OF TARGET WEBSITE BY WAF BYPASS SQL INJECTION.....	62
FIGURE A.5.2.1 : VULNERABILITY TEST OF TARGET SITE USING CYBERFOX BROWSER.	63
FIGURE A.5.2.2 : NUMBER OF COLUMN IDENTIFICATION USING CYBERFOX BROWSER.....	64
FIGURE A.5.2.3 : CHANGED NUMBER OF COLUMN BY CHANGING INJECTION POINT.	65
FIGURE A.5.2.4 : ERROR BASED COMMAND TO GET THE TABLE VERSION.	65
FIGURE A.5.2.5 : DATA DUMP USING ERROR BASED SQL INJECTION.	66
FIGURE A.5.3.1 : VULNERABILITY TEST OF TARGET SITE USING CYBERFOX BROWSER.	67
FIGURE A.5.3.2 : NUMBER OF COLUMN IDENTIFICATION USING CYBERFOX BROWSER.....	68
FIGURE A.5.3.3 : CHANGED NUMBER OF COLUMN BY CHANGING INJECTION POINT.	69
FIGURE A.5.3.4 : X-PATH BASED COMMAND TO GET THE TABLE VERSION.....	69
FIGURE A.5.3.5 : DATA DUMP USING X-PATH BASED SQL INJECTION.....	70
FIGURE A.6.1.1 : TARGET SITE ACCESS BY BASIC SQL INJECTION.	71
FIGURE A.6.1.2 : AN UPLOADER TO UPLOAD A SHELL.	71
FIGURE A.6.1.3 : UPLOAD THE SHELL.	72
FIGURE A.6.1.4 : SHELL UPLOAD SUCCESSFUL.	73
FIGURE A.7.1.1 : SKEYLOGGER INSTALLATION IN KALI LINUX.	74
FIGURE A.7.1.2 : RUNNING SYSTEM INTERFACE OF KALI LINUX.	75
FIGURE A.7.1.3 : CLOSING RUNNING SYSTEM IN KALI LINUX.	75
FIGURE A.8.1.1 : LFI TARGET SITE INTERFACE.	76
FIGURE A.8.1.2 : LFI PAYLOAD DIRECTED TO A PHP FILE.	76
FIGURE A.8.1.3 : LFI PAYLOAD TO A TARGET SITE.	77
FIGURE A.9.1.1 : CREATING AND LOGIN TO THE ACCOUNT.....	78
FIGURE A.9.1.2 : CSRF TOKEN CAPTURED BY BURP.	78
FIGURE A.9.1.3 : GENERATION OF CSRF POC.	79
FIGURE A.9.1.4 : MODIFICATION OF SCRIPT USING AUTO SUBMIT SCRIPT.	80
FIGURE A.9.1.5 : SCRIPT IS CONVERTED TO URL AND DELIVERED FOR CSRF ATTACK EXECUTED SUCCESSFULLY.....	81
FIGURE A.9.2.1 : TARGET INTERFACE FOR XSS VULNERABILITY.....	82
FIGURE A.9.2.2 : XSS ATTACK SUCCESSFUL EXECUTION ON TARGET SITE.....	82
FIGURE A.10.1.1 : BURP SUITE INTERFACE.....	83
FIGURE A.10.1.2 : BURP SUITE PROXY CONNECTED TO BROWSER TO INTERCEPT REQUEST.	84
FIGURE A.10.1.3 : BURP SUITE REQUEST SEND TO INTRUDER FOR PAYLOAD ATTACK.	84
FIGURE A.10.1.4 : BURP SUITE ATTACK SELECTED FOR BUTTERING RAM.....	85
FIGURE A.10.1.5 : BURP SUITE PAYLOAD COLLECTION.....	85
FIGURE A.10.1.6 : BURP SUITE NO REDIRECT SELECTED FOR PAYLOAD ATTACK.	86
FIGURE A.10.1.7 : BURP SUITE RESULTS FOR SUCCESSFUL ACCESS TAKEN BY PAYLOAD TEST.	86
FIGURE A.11.1.1 : LAB SESSION TASK BY PORTSWIGGER.	87
FIGURE A.11.1.2 : CHANGE MAIL COOKIE AND CSRF TOKEN CAPTURED BY BURP SUITE.....	87
FIGURE A.11.1.3 : CHANGE POST METHOD TO GET METHOD AND GENERATION OF CSRF POC.....	88
FIGURE A.11.1.3 : EXTRACTED SCRIPT IS DELIVERED EXPLOIT TO VICTIM.....	89
FIGURE A.11.1.4 : PORTSWIGGER CSRF LIVE LAB SOLVE.	90
FIGURE A.12.1.1 : KEY-MON, PYTHON INSTALLED.	91
FIGURE A.12.1.2 : ADMIN PANEL EXTRACTION BY FFUF.	92
FIGURE A.12.1.3 : ADMIN PANEL EXTRACTION USING FFUF IN KALI LINUX.	93
FIGURE A.13.1.1 : NMAP INTERFACE IN KALI LINUX.	94
FIGURE A.13.1.2 : NMAP INTERFACE IN VPS.....	94
FIGURE A.13.1.3 : NMAP EXPLOIT DETECTION.	95
FIGURE A.13.1.4 : NMAP PORT SCAN.	96
FIGURE A.13.1.5 : NMAP TOP PORT SCAN.	97
FIGURE A.13.2.1 : NMAP FIN SCAN.	98
FIGURE A.13.3.1 : NMAP XMAS SCAN.....	98

FIGURE A.13.4.1 : TCP SCAN.....	99
FIGURE A.13.5.1 : UDP SCAN.....	99
FIGURE A.14.1.1 : TARGET SITE SETUP AND FULL SCAN SELECTION.	100
FIGURE A.14.1.2 : DIFFERENT TYPES OF VULNERABILITYREPORT USING ACUNETIX.....	102

Nomenclature

Acronyms

Symbol	Description
<i>SQL</i>	Structured Query Language
<i>URL</i>	Uniform Resource Locator
<i>OSINT</i>	Open Source Intelligence
<i>IP</i>	Internet Protocol
<i>GPS</i>	General Positioning System
<i>DOS</i>	Denial of Service
<i>DDOS</i>	Distributed Denial of Service
<i>HOIC</i>	High Orbit Ion Canon
<i>DBMS</i>	Database Management System
<i>WAF</i>	Web Application Firewall
<i>IDS</i>	Intrusion Detection Systems
<i>IPS</i>	Intrusion Prevention Systems
<i>ISP</i>	Internet Service Provider
<i>USB</i>	Universal Serial Bus
<i>LFI</i>	Local File Inclusion
<i>CSRF</i>	Cross Site Request Forgery
<i>XSS</i>	Cross Site Scripting
<i>POC</i>	Proof of Concept
<i>IOS</i>	Iphone Operating System
<i>FFUF</i>	Fuzz Faster U Fool
<i>UDP</i>	User Datagram Protocol
<i>TCP</i>	Transmission Control Protocol

Symbol	Description
<i>VPS</i>	Virtual Private Server

**For Full Access Contact
Thank You**